

Technically Enforceable Data Sovereignty Across Untrusted Infrastructure

A Research Problem Statement and Investigation Framework

Version: 1.0 **Date:** 9 October 2026 **Document type:** Public research problem statement **Research status:** Initial investigation; no novel mechanism or universal solution is claimed.

Abstract

Organisations increasingly rely on external cloud infrastructure, AI services, software platforms, and connected systems to perform sensitive work. Encryption in transit and at rest, access controls, privacy-enhancing cryptography, confidential computing, and remote attestation offer important protections, but their guarantees depend on the workload, threat model, trusted components, output interface, and operational boundary.

This paper frames a research question: **Can an organisation define, enforce, and independently verify purpose-bound constraints on protected information across an external computation's observable lifecycle—inputs, execution, outputs, persistence, onward transfer, and future access—while clearly identifying what cannot be controlled after information has been observed or copied?**

The paper reviews the problem at a high level, distinguishes policy commitments from technical enforcement, identifies relevant existing technology areas, defines adversary classes and candidate security properties, and proposes a falsifiable evaluation programme. It does not claim that existing approaches are ineffective, that the problem has never been studied, or that a novel solution has been demonstrated. The immediate contribution is a bounded research agenda: map existing approaches to lifecycle properties, identify any specific evidence-supported gap, and test it under an explicit threat model.

Keywords: data sovereignty; privacy-enhancing technologies; confidential computing; remote attestation; purpose limitation; information-flow control; data usage control; output leakage; verifiable computation.

1. The Problem

Organisations increasingly need capabilities they do not operate themselves: large-scale computation, AI inference, specialised software, cloud storage, data exchange, and connected services. The provider may be able to deliver a useful capability while also operating parts of the infrastructure that process or store the organisation's information.

This creates a control question that is broader than conventional perimeter security: what can the organisation technically constrain the provider, workload, or downstream recipient from doing with information once the service has received it or derived something from it?

Relevant concerns include:

- access to plaintext during processing;
- retention in logs, caches, crash dumps, telemetry, replicas, or backups;
- reuse for a purpose different from the authorised task;
- disclosure to operators, subcontractors, or downstream services;
- inference from outputs, repeated queries, metadata, or derived artifacts;

- continued access after authority is revoked;
- evidence available to an independent party to verify what actually occurred.

These are different properties. A control that protects input confidentiality does not necessarily prevent output inference. A control that blocks future key release cannot recall information already disclosed. A valid attestation does not, by itself, prove that application behaviour is benign or that every output complies with a business purpose.

The research therefore should not treat “data sovereignty” as one binary property. It should decompose it into explicit, testable guarantees and state their assumptions.

2. Central Research Question

Can an organisation define, enforce, and independently verify purpose-bound constraints on protected information across an external computation's observable lifecycle—inputs, execution, outputs, persistence, onward transfer, and future access—while explicitly identifying residual risks and the limits of control after information has been observed or copied?

This question is deliberately conditional. It does not presuppose that a new technical mechanism is required, that all lifecycle controls can be enforced, or that current technologies are insufficient. The first task is to determine what existing systems already provide and under which assumptions.

2.1 Supporting questions

- Which security properties can be delivered by cryptographic techniques, and which require trusted execution, policy enforcement, operational controls, or legal agreements?
- What can remote attestation establish about a platform, workload, software measurement, or runtime state—and what does it not establish?
- How can authorisation be bound to a particular purpose, data scope, workload identity, output policy, and time window?
- How can outputs and repeated queries be evaluated for disclosure or inference risk?
- What evidence can the data owner or an independent verifier obtain without relying solely on provider assertions?
- What can be revoked prospectively, and what cannot be undone after information has been observed, copied, or learned?
- Can the guarantees be tested across different providers or execution environments?

3. Why Existing Security Controls Are Not Interchangeable

3.1 Encryption in transit and at rest

Transport encryption protects data while it traverses a protected channel; storage encryption protects stored data under its key and implementation assumptions. Neither guarantee alone resolves how plaintext is handled by a conventional application after decryption, what outputs reveal, or whether copies persist in other system components.

3.2 Privacy-enhancing cryptography

Privacy-enhancing cryptography includes techniques such as secure multiparty computation (MPC), fully homomorphic encryption (FHE), zero-knowledge proofs, private information retrieval, and related methods. These techniques have different security definitions, supported computations, leakage profiles, and performance costs. They can reduce the need to disclose raw inputs, but they do not automatically establish that every output is safe, that a business purpose is enforced, or that all downstream copies are controlled.

3.3 Confidential computing and remote attestation

Confidential computing uses hardware-backed isolation to protect data in use under a specified trusted computing base. Remote attestation can provide evidence about measured platform or workload state. A policy can condition key release or

access on accepted evidence.

These controls have boundaries. Attestation only establishes what its evidence, measurements, trust chain, freshness checks, and verifier policy actually cover. It does not independently prove that application semantics are appropriate, that an output reveals no protected information, or that data already exported has been erased.

3.4 Access control and usage control

Access control answers whether an actor may perform an operation under a policy. Usage-control approaches may attempt to constrain ongoing use, obligations, or subsequent actions. The research must compare these established areas rather than assume that purpose-bound policy enforcement is new.

3.5 Output and inference risk

A system may protect raw inputs while exposing sensitive facts through responses, repeated queries, model behaviour, metadata, or derived artifacts. Output granularity, query limits, privacy budgets where applicable, and result review may be relevant controls. The effectiveness of each control depends on the task and adversary.

3.6 Revocation and deletion

Revocation can deny future operations or future key release. Deletion mechanisms can remove or render inaccessible certain copies within a defined system boundary. Neither should be described as recalling information already observed, copied, exported, or incorporated into a learned or derived artifact. Any deletion claim must state exactly what was deleted, where, how it was verified, and what remains outside the verification boundary.

4. Threat Model

The investigation distinguishes at least the following adversaries. A result against one class must not be presented as a result against all classes.

- **Honest-but-curious service:** follows the declared protocol but analyses all permitted inputs, outputs, and metadata.
- **Privileged infrastructure operator:** can administer the host environment but is assumed not to break the specified hardware isolation or cryptography.
- **Malicious provider or workload operator:** attempts to alter software, broaden access, retain outputs, bypass policy, or request additional authority.
- **Compromised workload or dependency:** approved software contains a vulnerability, malicious component, unsafe plugin, or supply-chain compromise.
- **Compromised hardware, firmware, or attestation path:** the root of trust or evidence used to approve execution is defective or subverted.
- **Authorised but malicious user:** uses legitimate access to extract or disclose more than the intended purpose permits.
- **Downstream recipient:** receives an output or artifact and combines it with auxiliary information.
- **Legal or jurisdictional compulsion:** an operator may be required to disclose information it possesses or controls.

The evaluation must state its trusted computing base, including hardware, firmware, hypervisor or monitor, attestation services, workload image, dependencies, key authority, policy engine, output gateway, and evidence store where applicable.

4.1 Explicit limitations

This research does not assume that cryptography defeats every physical attack, that confidential computing eliminates all side channels, that attestation proves an application is benevolent, that outputs can always be made non-informative, or that a provider can be prevented from disclosing plaintext already available to it. Guarantees must be scoped to a stated adversary and implementation.

5. Candidate Security Properties

The following are properties to investigate, not claims of a completed system.

Property	Test question	Boundary or limitation
Input minimisation	Does the external service receive only fields required for the declared task?	"Required" must be specified and checked against actual payloads.
Key custody	Can an unapproved actor obtain the protected data key?	Depends on key generation, recovery, rotation, implementation, and trust assumptions.
Attested execution	Is authority released only when evidence meets a defined policy?	Evidence proves only what is measured and checked.
Purpose binding	Can a capability be reused for a different purpose, resource, or time window?	Enforcement may fail if the policy engine or workload is compromised.
Output control	Are output fields, precision, rate, and query volume constrained?	Inference may remain possible through repeated outputs or auxiliary data.
Retention control	Are known persistence paths prevented, controlled, or observable?	Cannot prove absence of copies outside the controlled boundary.
Revocation	Does revocation deny future key release and operations within a defined time?	Does not recall information already disclosed.
Independent verification	Can a verifier validate evidence without relying only on provider assertions?	Depends on the evidence source, verifier, and trust chain.
Audit integrity	Can tampering, omission, or reordering of relevant events be detected?	Logs may reveal sensitive metadata and require their own protection.
Portability	Do equivalent policies work across multiple execution environments?	Provider-specific APIs, hardware, and attestation formats may limit portability.

6. Related Work and Research Position

The initial review identifies substantial prior work in privacy-enhancing cryptography, verifiable privacy-preserving computation, confidential computing, remote attestation, inference-time privacy, and remote data-use control.

A 2025 survey by Bontekoe, Karastoyanova, and Turkmen compares 41 schemes for verifiable privacy-preserving computing over distributed data. It discusses privacy, correctness, efficiency, practicality, and limitations including the difficulty of public verifiability in TEE-based approaches and dependence on hardware trust. This establishes that privacy and verifiability are already a substantial research field.

MITRE's 2026 public-review framework for continuous remote attestation addresses runtime integrity, policy-based evidence appraisal, attested transport, trust-state changes, and AI workload considerations. It is a public-review draft, not to be described as a final standard unless a final version is confirmed. Its existence means that generic continuous attestation is not an appropriate novelty claim.

US Patent 12,483,393 B2 is an adjacent prior-art lead for remote data control using a confidential-computing proxy and provider-signed control signals. Its relevance requires careful claim-by-claim analysis; a patent record alone is not a legal opinion on validity, infringement, novelty, or freedom to operate.

The initial review is selective, not systematic. It does not establish that the candidate lifecycle question is novel or that existing products fail to address it. The next research stage must review purpose-based access and usage control, sticky policies, information-flow control, secure provenance, data-centric security, remote data-use control, output-inference protections, deletion verification, and AI tool-use policy enforcement.

7. Proposed Evaluation Programme

The initial experimental programme should be narrow and falsifiable. It should test a defined control boundary rather than attempt to prove universal data sovereignty.

Experiment 1: Attestation-gated key release

Claim under test: A key authority releases a protected data key only when the presented workload/platform evidence satisfies a specified policy.

Tests:

- approved workload and fresh evidence: release succeeds;
- modified workload measurement: release is denied;
- stale or invalid evidence: release is denied;
- revoked workload identity or policy: subsequent release is denied;
- unavailable verification service: protected operation fails closed, unless a separately justified availability rule applies.

Measure: release/denial result, latency, evidence freshness, policy version, and reproducibility. This test validates a narrow access-control property only; it does not prove output safety or end-to-end lifecycle control.

Experiment 2: Purpose replay

Claim under test: A task-bound capability cannot be reused outside its declared purpose, resource, or time window.

Test the same capability against the approved operation and against a different operation, resource, and time window. Record enforcement point and evidence. The test must include replay, concurrency, and revocation cases.

Experiment 3: Output leakage

Claim under test: The defined output policy reduces disclosure under a stated inference attack compared with a baseline.

Define the protected fact, permitted output, adversary knowledge, query budget, baseline attack success, and acceptance threshold before running the experiment. A functional test alone is not evidence of privacy.

Experiment 4: Lifecycle evidence

Claim under test: An independent verifier can reconstruct the relevant authorization, workload identity, key-release decision, output policy decision, and revocation events from integrity-protected evidence.

Test event omission, alteration, replay, and reordering. Explicitly identify events the provider could hide and evidence the verifier cannot independently obtain.

Reporting requirements

Each experiment must publish its threat model, hardware/software versions, configuration, test inputs, expected outcomes, observed outcomes, reproduction instructions, limitations, and residual risks. Failed tests must be reported rather than omitted.

8. Success Criteria and Decision Gate

The research may claim a specific technical gap only if all of the following are satisfied:

- The relevant prior work has been reviewed at full-text level.
- The gap is stated as a property and adversary, not as a broad aspiration.
- The gap is not already covered by an existing mechanism under equivalent assumptions.
- A reproducible experiment can distinguish success from failure.
- The evidence supports the exact claim and no stronger claim.
- Limitations and residual risks are disclosed.

If no distinct gap is established, the work should be reframed as a comparative evaluation framework for lifecycle control rather than as a novel security mechanism.

9. Current Status and Limitations

This document is a public research problem statement and investigation framework. It is not a systematic review, a formal security proof, a completed implementation, an experimental result, or a claim of patent novelty.

The current source set is selective. Full-text literature review, patent-family and independent-claim analysis, standards comparison, jurisdiction-specific legal review, and experimental validation remain outstanding. All claims should be interpreted within these limitations.

10. Conclusion

The relevant question is not whether data can be protected by one technology. It is which combinations of controls can provide specified, independently verifiable guarantees over a defined part of an information lifecycle—and what remains outside those guarantees.

The immediate objective is to map existing mechanisms to lifecycle properties, identify any specific gap supported by evidence, and test it under a defined threat model. The research remains open until that work is complete.

References

- National Institute of Standards and Technology (NIST). **Privacy-Enhancing Cryptography**. <https://csrc.nist.gov/Projects/pec>
- NIST. **Fully Homomorphic Encryption**. <https://csrc.nist.gov/Projects/pec/fhe>
- NIST. **NIST IR 8320E, Hardware-Enabled Security: Confidential Computing of Data in Cloud Workloads, Initial Public Draft** (29 May 2026). <https://csrc.nist.gov/pubs/ir/8320/e/ipd>
- Bontekoe, T., Karastoyanova, D., & Turkmen, F. **Verifiability for privacy-preserving computing on distributed data — a survey**. *International Journal of Information Security* 24, Article 141 (2025). <https://doi.org/10.1007/s10207-025-01047-7>
- Sardar, M. U., & Fetzer, C. **Confidential computing and related technologies: a critical review**. *Cybersecurity* 6, Article 10 (2023). <https://doi.org/10.1186/s42400-023-00144-1>
- MITRE. **Framework for Continuous Remote Attestation in Confidential Computing Environments**, public-review v0.9.6 (16 July 2026). <https://www.mitre.org/news-insights/publication/framework-continuous-remote-attestation>
- U.S. Patent 12,483,393 B2. **Method of controlling remote data based on confidential computing and system thereof** (issued 25 November 2025). <https://patents.google.com/patent/US12483393B2/en>
- Jegorova, M. et al. **Survey: Leakage and Privacy at Inference Time**. *IEEE Transactions on Pattern Analysis and Machine Intelligence* 45(7), 9090–9108 (2023). <https://doi.org/10.1109/TPAMI.2022.3229593>
- **Confidential Computing across Edge-to-Cloud for Machine Learning: A Survey Study**. *Software: Practice and Experience* 55(5), 896–924 (2025). <https://doi.org/10.1002/spe.3398>

Reference note: This is a selected bibliography, not a complete systematic bibliography. Verify final metadata and all source-to-claim mappings before journal or conference submission.